SPOTIFY'S DATA & AI GOVERNANCE PROJECT

3. *Data & AI Governance Implementation* Plan

> *Nicolas Pichon --- AIA RNCP 38777 / BC01 / Step 3 / v15 --- 2026/10/15.*

3.1. Objectifs

Ce document présente un plan d'implémentation de la gouvernance des données et des modèles dans le cadre du projet de gouvernance *Spotify* [R2]. Le plan proposé est motivé par les objectifs suivants :

1. Outiller les rôles opérationnels de moyens techniques adaptés de leurs responsabilités ;
2. Établir une source unique de vérité et un catalogue commun ;
3. Valider la viabilité du modèle organisationnel et des outils retenus sur un périmètre limité ;
4. Elever tous les niveaux de maturité jusqu'au niveau 3 de l'échelle du *DMAT* [R1], en priorisant les dimensions *Data Governance*, *Data Quality*, *Compliance* et *Data Security*.

3.3. Modèle organisationnel

Le modèle d'organisation dit "*Center of Excellence*" (*CoE*) [R7] formalise l'organisation de la gouvernance des données et des modèles déjà structurée dans [D22], à quelques adaptations près.

CoE combine normalement un centre de compétences qui regroupe l'autorité de gouvernance et les services techniques partagés avec des départements de métier partiellement autonomes qui conservent la responsabilité opérationnelle de leurs données. L'organisation [D22] s'écarte du modèle canonique sur ces deux points : 1) en maintenant l'infrastructure et les compétences techniques dans le département *Engineering* ; 2) en séparant l'autorité de conformité (représentée par les rôles *DPO* et *Legal Team*) de l'autorité de gouvernance (représentée par les rôles *CDO* et *DGC*).

3.4. Outils

Chaque outil équipe un rôle précis du modèle *CoE* et répond à un enjeu identifié en [D1]. La sélection suivante résulte d'une comparaison des outils recommandés dans [R8] avec des alternatives *open source*.

Catégorie	Sous-catégorie	Outil	Opérateurs	Enjeux	Licence
Catalogage	Glossaire & Workflows	Collibra [R8]	DS, DO	E1, E3	Propriétaire
Catalogage	Inventaire & lineage	OpenMetadata	DC	E1	Apache 2.0
Qualité	Contrôle courant & datasets d'entraînement	Soda Core	DS, MO	E2, E5	Apache 2.0
Conformité	RoPA/DPIA/BN/DSAR	TrustArc [R8]	DPO, Legal	E3, E4	Propriétaire
Sécurité	SIEM	Wazuh	DC	P3	GPLv2
Sécurité	Chiffrement & clés	OpenBao	DC	P3	MPL-2.0
Sécurité	Centre IAM (identifiants dynamiques)	OpenBao	DC	P3	MPL-2.0
Gouvernance IA	Catalogage des modèles & lineage des datasets	MLflow	MO	E5	Apache 2.0
Gouvernance IA	Versionage des datasets	DVC	MO	E5	Apache 2.0
Gouvernance IA	Détection des biais	AIF360	MO, MRM	E5	Apache 2.0
Gouvernance IA	Explicabilité	AIX360	MRM	E5	Apache 2.0

> *Glossaire :*
>
> - *Enjeux : [D1] ; Principes : [D21] ; Rôles : [D22] ;*
> - *Sécurité : SIEM = Security Information and Event Management, IAM = Identity and Access Management* ;
> - *Conformité :*
>   - *RoPA = Record of Processing Activities (RGPD, art. 30),*
>   - *DPIA = Data Protection Impact Assessment (RGPD, art. 35),*
>   - *BN = Breach Notification (RGPD, art. 33 & 34),*
>   - *DSAR = Data Subject Access Request (RGPD/CCPA) ;*

3.5. Plan pilote

Le plan pilote reprend la structure du modèle [R9] (périmètre, objectifs, équipe, calendrier, livrables, indicateurs, risques, formation) et l'adapte aux enjeux identifiés en [D1]. Les indicateurs sont adossés aux niveaux de maturité du *DMAT* [R1], plutôt qu'aux KPIs génériques proposés par [R9].

Périmètre retenu. Les *modèles et données d'entraînement du système de recommandation* (composé éventuellement de plusieurs modèles ML/IA) au sein du département *Product Development*.

Le moteur de recommandation est un avantage concurrentiel central de *Spotify*, et sa performance dépend directement de la qualité des données qui l'alimentent [R2].

Le périmètre retenu teste simultanément les mécanismes suivants en conditions réelles :

Mécanisme	**Enjeu**
Rattachement fonctionnel du *Data Steward* au *CDO*	E1
Outillage *Soda Core* (contrôle courant et données d'entraînement)	E2
Rôles *Model Owner*/*Model Risk Manager* et circuit de classification/approbation	E5
Déploiement incrémental de *Collibra* et du *RoPA* (*TrustArc*) au sein du périmètre pilote	E1, E3

E3/E4 restent hors du périmètre principal : la conformité *RGPD* globale implique un déploiement complet de la plateforme (un *RoPA* appliqué à un seul département ne fait pas la conformité à l'article 30).

Objectifs. (1) Valider le rattachement fonctionnel *DS*/*CDO* sur un cas réel de décompartimentation. (2) Mesurer l'*engineering overhead* des *Data Custodians* - hors infrastructure et maintenance pluriannuelle. (3) Classifier les modèles testés selon leur niveau d'impact et éprouver le circuit d'approbation sur des versions successives. (4) Trancher les points de vigilance techniques : recouvrement *OpenMetadata*/*Soda Core*, couverture E5 par *Soda Core*, charge *IAM* et détection transférée à *Wazuh*/*OpenBao*, fonctionnement du connecteur *Collibra*/*OpenMetadata*, et synchronisation de groupes via *SSO* (confirmée pour *OpenMetadata* et *Collibra*, non documentée pour *TrustArc*). (5) Valider la viabilité du déploiement incrémental de *Collibra* et du *RoPA*. (6) Vérifier que la population du *RoPA* dispose d'une classification préalable des données traitées. (7) Conduire la migration de sécurisation obligatoire du stockage initial : régénération des secrets, collecte exhaustive des profils et droits d'accès existants, redéfinition via *OpenBao* (module *AWS Secrets Engine*) et l'annuaire d'entreprise partagé.

Équipe. *Pilot Project Manager* (coordination, reporting *DGC*), *DS* (qualité domaine, double rattachement, glossaire *Collibra*) , *MO* (*MLflow*, *AIF360*, classification), *MRM* (revue, validation, dossier d'approbation), *DO* (arbitrage métier), *DC* (déploiement technique, migration de sécurisation, Engineering overhead), *DPO*/*Legal Team* (population du *RoPA*).

Calendrier (21 semaines).

Jalon	**Semaines**	**Actions**
A	S1-S7	**Phase de sécurisation** (*) : existence d'un annuaire central *SAML*/*OIDC*, sécurisation des infrastructures préexistantes, vérification *SSO* de *TrustArc* et *RBAC* des autres outils, test d'intégration bout-en-bout, revue de validation.
B	S8-S11	Déploiement technique et population du *RoPA* (en parallèle, jusqu'à S17)
C	S12-S13	Vérifications de recouvrement *Soda Core*/*OpenMetadata* et du connecteur *Collibra* ;
		Population du glossaire *Collibra*
D	S14-S17	Classification du modèle puis exécution en conditions réelles
E	S16-S17	Vérification technique intermédiaire et revue intermédiaire
F	S18	Premier passage du circuit d'approbation
G	S19-S21	Consolidation, synthèse, clôture

> *Glossaire* : *SSO* = *Single Sign-On*, *RBAC* = *Role-Based Access Control* ;
> (*) Phase *bloquante* : le projet ne peut pas passer aux étapes suivantes tant que la sécurisation de l'infrastructure n'est pas validée;

Livrables. Rapport qualité des données, rapport de validation du circuit de classification/approbation, estimation de l'*engineering overhead*, note de recouvrement technique (repli *TestGen*/*Cuallee* si besoin), note de synchronisation du catalogage, note de contrôle d'accès (*RBAC*/*SSO*) , rapport de migration de sécurisation, rapport de déploiement incrémental *Collibra*/*RoPA*, retours des parties prenantes, rapport d'évaluation du double rattachement.

Indicateurs. 1) Trois dimensions *DMAT* [R1] sont réévaluées : *Data Governance* et *Data Quality* du niveau 1 au niveau 2, *Analytics & BI* (volet *gouvernance IA*) : de 2 à 3; elles sont ancrées à des artefacts datés (logs *Soda Core*, workflows *Collibra*, dossiers de classification), validées par *DGC* au jalon G (S21). 2) Le double rattachement est évalué séparément par cinq indicateurs : a) adoption des standards, b) délai de propagation, c) fréquence de sollicitation, d) cohérence terminologique (captés nativement via *Collibra*), e) autonomie départementale (registre minimal dédié). Ces indicateurs sont combinés au critère de passage à l'échelle du double rattachement (absence de conflit d'autorité rapporté) pour éviter qu'un canal inutilisé passe pour un succès (conflits non tracés).

Risques. A) Deux risques propres à la phase de sécurisation : 1) *suspension du projet sans solution de repli* (l'absence d'annuaire central est un défaut de sécurisation bloquant qui ne peut pas être corrigé dans le jalon A), et 2) *débordement de planning* (délai de réponse de *TrustArc*, échec du test d'intégration bout-en-bout sans marge pour une seconde itération, exécution en conditions réelles compressée sur 4 semaines). B) S'y ajoutent les risques opérationnels : a) sous-estimation de la charge des *Data Custodians* (3 outils sur 10) ; b) collecte incomplète des profils d'accès existants (accès orphelins après bascule vers *OpenBao*) ; c) insuffisance de *Soda Core* pour E5 (repli *Cuallee*) ; d) dépriorisation à long terme de *Soda Core* au profit de *Soda Cloud* (repli *TestGen*) ; e) absence de classification préalable des données, condition de la fiabilité du *RoPA* ; f) désalignement avec les cycles budgétaires trimestriels lors des transitions inter-phases.

Formation. Session dédiée au *Data Steward* et au *Product Manager* sur le mécanisme de double rattachement (E6), et sur la répartition entre autorité fonctionnelle (*CDO*) et organisationnelle (département). Revue finale (jalon G) structurée en trois axes : 1) ce qui a fonctionné mieux que prévu, 2) ce qui a nécessité un ajustement, ce qui reste non résolu.

3.6. Feuille de route de généralisation

Conditions de passage à l'échelle. Chaque dispositif reçoit une décision de type "feu vert/orange/rouge", adossée aux KPIs et aux risques du pilote : double rattachement (absence de conflit d'autorité), recouvrement *Soda Core*/*OpenMetadata* (décision au jalon C (S12)), connecteur *Collibra*/*OpenMetadata* (jalon C (S13)), capacité *Soda Core* / E5 (validée entre les jalons C (S12) et E (S16), sinon repli), circuits de classification/approbation (délais mesurés au jalon F, resserrement des critères si circuits trop lents), déploiement incrémental *Collibra*/*RoPA* (extensible sans reconstruction majeure), *engineering overhead* (séquencement pluriannuel si charge intenable), phase de sécurisation (franchissement du jalon A (S7)).

Séquencement. Le pilote ne couvre qu'un sous-ensemble d'un seul département ; les autres activités du département *Product Development* et les autres départements de l'organigramme [D22] restent à couvrir. Le niveau de risque et le coût marginal dictent le séquencement de la généralisation: *Marketing* en priorité pour E3 et E4, suivi de *Content Curation* pour E2 et les métadonnées. Avec ces trois départements (*PD*, *MKT*, *CC*), les périmètres que [R2] désigne comme prioritaires (données utilisateur, métadonnées de contenu, données marketing) sont tous couverts.

La phase de sécurisation (jalon A) n'est pas reproduite aux phases suivantes : l'annuaire central, les rôles *OpenBao* et les intégrations *SSO* déjà validés sont étendus - seule une migration allégée (régénération des secrets, collecte des profils) est reconduite pour chaque nouveau département.
D'où une durée canonique de phase réduite pour les phases 2 à 4, et une marge inter-phases renforcée pour absorber le risque d'alignement aux cycles budgétaires trimestriels :

Phase	Périmètre	Durée	Marge	Fin cumulée
1 (pilote)	*Product Development* :	21 sem.	2 mois	M5
	- entraînement recommandation	(~5 mois)		
	- sécurisation complète			
2	*Product Development* :	3 mois	2 mois	M10
	- activités restantes			
3	*Marketing* :	3 mois	2 mois	M15
	- E1/E3/E4			
	- risque réglementaire le plus élevé			
4	*Content Curation* :	3 mois	-	M20
	- E2, métadonnées			
Consolidation	Ensemble des départements :	-	-	M22-M24
	- niveau 3 généralisé			

Ce séquencement consomme la totalité du budget de référence recommandé dans [R11, Q7] (15-24 mois). C'est le coût cumulé, et assumé, de la phase de sécurisation et des marges inter-phases renforcées.

Ajustements attendus. Calibration des seuils des critères des niveaux d'impact des modèles selon les résultats du pilote ; Révision du tableau d'outils sur les deux lignes explicitement testées (recouvrement *Soda Core*/*OpenMetadata*, capacité *Soda Core* / E5) ; Etablissement d'un coût total de possession (infrastructure, maintenance pluriannuelle) à partir d'un historique d'exploitation suffisant ; Validation de la couverture *DSAR* par *TrustArc* comme exercice séparé, porté par *DPO*/*Legal Team*, avant l'ouverture de la phase 3, en s'appuyant sur le *RoPA* déjà peuplé. Documentation de l'extension légère de sécurisation répétée pour chaque nouveau département (régénération des secrets, collecte des profils) .

Trajectoire de maturité. Niveau 2 sur le périmètre pilote à M5 → niveau 2-3 étendu à tout *Product Development* (M10) → Compliance et Data Usage via *Marketing* (M15) → niveau 3 sur Metadata via *Content Curation* (M20) → niveau 3 généralisé à l'ensemble des départements (M22-M24), conformément à l'objectif fixé en [D21, §2.1.7]. Cette trajectoire reste indicative : chaque jalon de phase est un point de réévaluation, la feuille de route étant elle-même soumise au principe d'amélioration continue qu'elle sert à mettre en œuvre.

Références

Livrables

- [D1] *Data Maturity Assessment Report*
- [D21] *Data Governance Policy Document*
- [D22] *Organizational Chart*

Annexes

- [D3-Annexes] *Implementation Plan's Annexes*

Ressources

- [R1] Australian Government Data Maturity Assessment Tool (2026)
- [R2] Spotify Business Case
- [R7] Organizational Models Overview
- [R8] Tech Tools Overview
- [R9] Pilot Implementation Template
- [R11] Executive Q&A Guide

Documents Applicables

- [A1] **[GDPR]** *General Data Protection Regulation* - Règlement (UE) 2016/679, 27 avril 2016. JO L 119, 4.5.2016.